3.1 2FA

Section lead: Brain Peer reviewed by: Haneef

Two factor authentication (2FA) and multi factor authentication (MFA) are security procedures and mechanisms that are designed to reduce the risk of unauthorised account access. Traditional password only authentication relies on a single piece of information that can be stolen, guessed or obtained through other ways like phishing and social engineering attacks. MFA adds an additional layer of security and authentication factor. Meaning that just possessing the password of an account shouldn't be enough to access an account and the information on it. The National Institute of Standards and Technology (NIST) defines three traditional authentication factor categories, something you know, something you have, and something you are (NIST, 2017).

3.2 Authentication factors and common methods

The first category, “something you know”, refers to information that is known by the user, such as a PIN or password. Passwords are widely used but can be vulnerable to phishing attacks, password reuse, credential stuffing and data breaches.

The second category, “something you have”, refers to an item or device controlled by the user, such as a mobile phone, authenticator app, or a physical security key.

The third category, “something you are”, refers to biometric characteristics, such as fingerprints, facial recognition technology and retinal scans. NIST explains that MFA involves using more than one of these different factor categories (NIST, 2017).

Common MFA methods usually include SMS codes, authenticator applications, and hardware security keys.

SMS authentication sends a one-time code to the user's registered mobile phone number, that is valid for a limited amount of time before being deleted and unusable. Although convenient and widely supported. SMS still does have security weaknesses. Attackers can potentially take control of a victim's mobile phone number through SIM swapping and some weaknesses in telecommunication infrastructure can also expose SMS authentication codes and be intercepted and used. NIST therefore classifies the use of SMS and voice calls through the public telephone network as a restricted authentication method because attackers have demonstrated the ability to obtain reassigned telephone numbers and intercept authentication messages (NIST, 2025).

Authenticator applications, such as Microsoft authenticator or Google authenticator. Generate one-time passwords or provide authentication prompts. These methods are generally stronger than traditional SMS one-time codes because they do not depend on the telephone network. However, one-time codes can still be stolen through phishing. The UK National Cyber Security Centre (NCSC) therefore places app-based authentication method below phishing resistant FIDO2 authentication in its recommended hierarchy (NCSC, 2024a).

Hardware security keys provide another form of “something you have”. Technologies such as FIDO2 use a public key cryptography and are designed to resist phishing because the authentication credential is cryptographically associated with the legitimate website. CISA describes security keys as providing strong protection against phishing, while NSCS identifies FIDO2 credentials as providing phishing and theft resistance (CISA, 2025) (NCSC, 2024a)

3.3 How effective is MFA at preventing account takeover?

Evidence from a Microsoft study indicates that MFA can substantially reduce the risk of account compromise, although its effectiveness depends on the methods of authentication used. A Microsoft study analysed suspicious activity involving Microsoft Azure Active Directory accounts between April and September 2022, the researchers estimated that MFA reduced the risk of account compromise by 99.22% across the overall population and by 98.56% for accounts where credentials had been leaked and compromised completely. The study also found that authenticator applications performed better than SMS authentication (Lucas A. Meyer, 2023)

This study provides useful evidence because it examined real account activity rather than relying solely on theoretical security models. However, the results should not be interpreted as meaning that every MFA implementation prevents 99.22% of attacks. Rather the research examined Microsoft's commercial account environment and a specific period of suspicious activity, so the results may not directly correlate and represent every organisation, individual or type of MFA.

Earlier research conducted by Google with researchers from New York University and University of California, San Diego also demonstrated the effectiveness of additional authentication challenges. In their study, SMS based challenges blocked 100% of automated bot attacks, 96% of bulk phishing attacks and 76% of targeted attacks in the investigated dataset. Device based prompts performed better against targeted attacks, blocking 90% of them (Thomas K., 2019)

These findings demonstrate an important distinction; MFA is not equally effective regardless of the method used. Stronger phishing resistant methods can provide greater protection than SMS or methods that require users to enter codes into websites.

3.4 Why do security organisations still recommend SMS MFA?

Despite its weaknesses, security organisations still continue to recommend enabling MFA, including SMS based MFA when stronger alternatives are unavailable. This is because SMS MFA still provides that additional barrier compared with the classic password only authentication method. The UK NCSC explicitly states that SMS is not the most secure type of 2 step verification but still provides a significant advantage over not using a second factor at all (NCSC, 2025)

There are also practical reasons for continuing to support SMS. Almost every mobile phone can receive text messages, meaning that users do not necessarily need to install a secondary application or purchase specialised hardware security keys, which could make things a lot more complicated. This makes SMS particularly useful for legacy systems and users who cannot access more advanced authentication methods and solutions. The NCSC therefore recommends message-based authentication primarily where stronger methods are not possible (NCSC, Why MFA matters, 2024b)

However, organisations should recognise the limitations of SMS authentication. CISA recommends stronger phishing resistant MFA methods, such as hardware-based FIDO authentication, and describes SMS as a weaker option (CISA, 2025). Therefore, SMS can be considered a practical minimum layer of security and protection rather than the strongest available MFA solution.

Overall, MFA significantly strengthens account security by requiring evidence from multiple authentication factors. Research from Microsoft and Google demonstrates that MFA can substantially reduce account compromise, but the level of protection varies according to the authentication method. SMS provides useful and the most simple and easy to deploy protection against many automated and credential-based attacks but remains vulnerable to more advanced techniques such as SIM swapping and phishing. Authenticator applications generally provide stronger protection, while FIDO2 security keys provide phishing resistant authentication. Consequently, organisations should implement MFA whenever possible while selecting authentication methods according to the security requirements, usability needs and risks associated with their systems.